

CAB Patch Decision Report

Change Advisory Board | CVE-2026-923386 | Pack PF-20260528-9e896f66

Generated 28/05/2026, 17:02:31. Governed posture: Urgent scope confirmation required - final remediation decision blocked pending evidence.. Readiness: Blocked.

Report Version Metadata

report_template_version	patchforge-report-template.v2026-05-28.1
report_renderer_commit	923b386
report_renderer_image_tag	pfaz9a-20260528-923b386
generated_from_pack_id	PF-20260528-9e896f66
generated_at_utc	2026-05-28T17:02:31.250Z
product_baseline	PF-AZ9A-VENDORLENS
report_context_version	patchforge-report-context.v2
source_pack_id	PF-20260528-9e896f66
report_type	cab_patch_decision_report
report_audience	Change Advisory Board
final_approval_issued	false
signing_provider	Azure Key Vault
verification_state	verified

Executive Decision Summary

CVE-2026-923386: Urgent scope confirmation required - final remediation decision blocked pending evidence. PatchForge has public-source vulnerability intelligence, but customer asset and service exposure assessment is incomplete. 4 evidence gap(s) remain, and final approval has not been issued.

Final approval not issued.

Recommended posture	Urgent scope confirmation required - final remediation decision blocked pending evidence.
Next best action	Confirm customer exposure and patch applicability before selecting emergency change, patch, mitigation, or risk acceptance.
Confidence	Medium
Human approval	Still required

CAB Decision Request

CAB is asked to review CVE-2026-923386 under governed posture Urgent scope confirmation required - final remediation decision blocked pending evidence.. Final approval not issued.

Patch Applicability

VendorLens applicability posture: Requires Review. Urgency: Urgent Scope Confirmation Required.

Affected Assets and Services

PatchForge has public-source vulnerability intelligence, but customer asset and service exposure are not yet confirmed. This gap matters because severity alone does not tell the CAB what could break, who owns it, or whether customer-facing operations are affected.

Network Vendor Applicability

Network vendor applicability context is attached as source-bound advisory intelligence.

Customer Configuration Context

Asset pfaz9a-val-fortigate-100f-923b386 uses Fortinet Firewall 7.2.7.

Patch / Workaround Evidence

Reviewed evidence and accountable ownership are required before CAB approval.

Change Readiness

Reviewed evidence and accountable ownership are required before CAB approval.

Test Evidence

Reviewed evidence and accountable ownership are required before CAB approval.

Rollback and Recovery

Reviewed evidence and accountable ownership are required before CAB approval.

Maintenance Window

Reviewed evidence and accountable ownership are required before CAB approval.

Implementation Ownership

Reviewed evidence and accountable ownership are required before CAB approval.

Approval Conditions

Human approval remains required. PatchForge does not approve CAB decisions, risk acceptance, patch deployment, or closure autonomously.

Required Evidence Before CAB Approval

- Reviewed Vulnerability Identity Evidence: Reviewed CISA/CVE/vendor advisory record confirming CVE, product, affected versions, and source provenance.
- Affected Asset Scope: CMDB, hosting control panel inventory, scanner output, asset owner confirmation.
- Business Service Impact: Service map, customer-facing flag, SLA/OLA impact, service owner.
- Human Source Review Event: Named reviewer decision accepting or rejecting source records.

Signed Pack and Audit Trace

Signed pack	PF-20260528-9e896f66
Source pack	PF-20260528-9e896f66
Verification state	verified
Governance manifest SHA-256	3872efe5b1a4def2c93f2972cb783c0737e52a838ecde949a4f9f234fc944cd8

What This Vulnerability Means

Temporary source-bound validation finding used to prove current PF-AZ9A report stamping. Customer exposure and configuration evidence are pending review, and final approval is not possible until source evidence, affected scope, and human approval are provided.

Why It Matters Now

It is flagged as known exploited in source-bound intelligence. The finding is marked internet-facing.

Affected Scope

PatchForge has public-source vulnerability intelligence, but customer asset and service exposure is not confirmed. This gap matters because severity alone does not tell the CAB what could break, who owns the asset, and which facing operations are affected.

Exploitability Intelligence

Exploit code, exploit payloads, and procedural exploitation steps are intentionally not provided.

Source-bound intelligence indicates this vulnerability is known to be exploited in the wild. CISA KEV indicates the vulnerability appears in a known exploited vulnerability source feed. EPSS provides a probability-style signal and may be lower. PatchForge treats these as prioritisation signals, not proof of tenant exposure. Customer exposure must be confirmed through asset and service evidence. The safe governance question is whether exposure, service impact, patch feasibility, and compensating controls justify patch, mitigation, deferral, or risk acceptance.

CISA KEV indicates the vulnerability appears in a known exploited vulnerability source feed. EPSS provides a probability-style signal and may be lower. PatchForge treats these as prioritisation signals, not proof of tenant exposure. Customer exposure must be confirmed through asset and service evidence.

Known exploited signal	Yes, source-bound pending review unless accepted
------------------------	--

EPSS score	0%
EPSS percentile	0%
Ransomware campaign use	Unknown
Can close gates alone	No

Recommended Action Plan

Defer Pending Evidence is the current advisory posture. A known-exploited public-source si reviewed customer asset and service exposure are not confirmed. This remains a governed prepare the evidence and report, but a human approver must issue the decision outcome.

- Confirm customer exposure and patch applicability before selecting emergency change, patch, mitigation, or risk acceptance.
- Attach affected asset scope evidence.
- Attach business service impact evidence.

Decision Snapshot

Vulnerability	CVE-2026-923386
Title	PF-AZ9A VendorLens FortiGate SSL VPN source-bound validation finding
Severity	Critical
Posture	Defer Pending Evidence
Readiness	Blocked
Final approval	Not issued

Decision Options

- Recommended: Urgent Scope Confirmation Required - Status: Recommended Now. Reason: Known-exploited public intelligence exists, but customer asset and service exposure are not confirmed.. Required evidence: Reviewed asset scope, Reviewed service impact, Source identity review. Approval: Security lead or service owner confirms the affected scope..
- Emergency Change Required - Status: Blocked. Reason: Emergency Change Required is blocked pending asset/service exposure and patch applicability.. Required evidence: Reviewed affected scope, Patch applicability, Rollback plan, Customer/ service impact, Human approval. Approval: CAB/security lead emergency approval..
- Patch Required - Status: Blocked. Reason: Patch Required is blocked pending patch availability, feasibility, and reviewed exposure scope.. Required evidence: Vendor patch note, Affected version mapping, Test evidence, Rollback plan, Service owner review. Approval: Change owner, service owner, and CAB/security approval..
- Mitigate Temporarily - Status: Blocked. Reason: Mitigate Temporarily is available only if compensating-control evidence is attached and reviewed.. Required evidence: Compensating control plan, Control owner, Monitoring evidence, Expiry or reassessment date. Approval: Security lead and service owner approve temporary mitigation..
- Risk Accept Temporarily - Status: Blocked. Reason: Risk Accept Temporarily is blocked until risk owner, rationale, expiry, compensating controls, and accountable approval exist.. Required evidence: Risk owner, Rationale, Expiry, Compensating controls, Residual risk statement. Approval: Named accountable risk owner approval..

Evidence Confidence and Gaps

- Reviewed Vulnerability Identity Evidence - Why it matters: CAB and customer assurance need confidence that the CVE, affected product, affected versions, and source provenance are correct before remediation decisions are presented as evidence-led. Required evidence: Reviewed CISA/CVE/vendor advisory record confirming CVE, product, affected versions, and source provenance. Owner/gate: Security lead or vulnerability manager; Source identity review.
- Affected Asset Scope - Why it matters: Without asset scope, the organisation cannot tell whether the public-source finding affects the customer estate or what operational risk a change would introduce. Required evidence: CMDDB, hosting control panel inventory, scanner output, asset owner confirmation. Owner/gate: Asset owner or infrastructure lead; Asset exposure confirmation.

- Business Service Impact - Why it matters: Severity alone does not tell the CAB which service, customer journey, SLA, or owner is affected. Required evidence: Service map, customer-facing flag, SLA/OLA impact, service owner. Owner/gate: Service owner; Business impact review.
- Human Source Review Event - Why it matters: Source-bound intelligence cannot become accepted positive evidence without a reviewer accepting or rejecting the source record. Required evidence: Named reviewer decision accepting or rejecting source records. Owner/gate: Security lead or CAB reviewer; Human evidence review.

Evidence, Trust, and Signing

Signed pack	PF-20260528-9e896f66
Verification	Verified
Signing provider	Azure Key Vault
Manifest hash	3872efe5b1a4def2c93f2972cb783c0737e52a838ecde949a4f9f234fc944cd8
Source pack	Immutable and preserved

Bayesian Advisory

Availability	Generated
Advisory boundary	Advisory only; cannot close gates or approve risk
Recommended posture	Defer Pending Evidence
Exploit probability posterior	68%
Business impact posterior	35%
Patch feasibility posterior	67%
Change risk posterior	52%
Deferral risk posterior	61%

Vendor and Threat Landscape

Vendor intelligence	Reviewed vendor advisory evidence has not yet been attached.
Vendor applicability	Patch maturity, affected versions, workaround guidance, and remediation applicability remain unverified.
Threat landscape	Threat metrics shown below are source-bound public-intelligence signals and do not close hard gates.
Active exploitation signals	13
Critical open advisories	2
Patch maturity	Unknown
Source review	Pending review unless explicitly accepted

Network Vendor Applicability

	VendorLens context is attached as source-bound advisory intelligence. It does not verify customer data and cannot approve a decision by itself.
Vendor	Fortinet
Advisory / CVE	CVE-2026-923386
Applicability posture	Requires Review
Urgency posture	Urgent Scope Confirmation Required

Final approval

Not issued

Customer Configuration Context

Asset	pfaz9a-val-fortigate-100f-923b386
Product family	Fortinet Firewall
Model	FortiGate 100F
Firmware / version	7.2.7
Enabled features	IPsec VPN
Disabled features	SSL-VPN

Affected Feature Assessment

Affected feature	SSL VPN
Affected version status	Affected
Feature enabled status	Disabled Unreviewed
Exposure status	Internet Or Management Exposed

Evidence Required to Prove Not Applicable

- SSL VPN is recorded as disabled, but that configuration evidence is not reviewed.: Reviewed configuration export, change record, service owner attestation, or device configuration evidence. Owner: Network engineering lead.
- The vendor/CVE source record has not been accepted as positive evidence.: Named reviewer event accepting the source record, affected versions, affected feature, and source provenance. Owner: Security lead.

Urgent Patch / Mitigation / Scope Confirmation Recommendation

Confirm vendor advisory source, customer asset, firmware, feature, and exposure evidence.

SRA/AIP Chat Summary

Session	pfaz9a-val-chat-923b386
Short answer	PatchForge cannot safely declare this configuration unaffected yet; complete scope and configuration evidence review first.
Governed posture	Urgent Scope Confirmation Required
Decision not allowed yet	Final remediation, risk acceptance, closure, and not-applicable decisions cannot be issued until the evidence gaps are resolved and a human reviewer approves the outcome.

Patch Version Comparison for CISO Review

This comparison shows the recorded running version against the target or fixed version for not deploy or approve a patch.

Vendor	Fortinet
Asset	pfaz9a-val-fortigate-100f-923b386
Advisory / CVE	CVE-2026-923386
Current version	7.2.7

Target / fixed version	7.2.8
Current version status	Current Version Not Listed As Affected Pending Review
Target version status	Target Version Recorded As Fixed Pending Review
Final approval	Not issued

Security Delta

The target version is recorded by the source advisory as the remediating or fixed branch for advisory for checking VendorLens applicability, report stamping, pack export, and cleanup. Target version is pending review and must not be treated as approved evidence.

Operational Delta and Evidence Required

- Confirm vendor release notes, fixed-version applicability, configuration dependencies, HA/cluster impact, and rollback support before approval.
- PatchForge records the comparison for CISO/CAB review only; it does not deploy or approve the change.
- Evidence required: Reviewed vendor advisory and release notes
- Evidence required: Current device firmware/version evidence
- Evidence required: Target version or fixed-version evidence
- Evidence required: Affected feature configuration evidence
- Evidence required: Testing evidence and rollback plan

CISO Summary

Current version 7.2.7 is compared with target version 7.2.8. The target is recorded as a fixed version in source-bound advisory data, pending review. Final approval has not been issued.

Blockers and Next Actions

- Reviewed Vulnerability Identity Evidence: Reviewed CISA/CVE/vendor advisory record confirming CVE, product, affected versions, and source provenance.
- Affected Asset Scope: CMDB, hosting control panel inventory, scanner output, asset owner confirmation.
- Business Service Impact: Service map, customer-facing flag, SLA/OLA impact, service owner.
- Human Source Review Event: Named reviewer decision accepting or rejecting source records.

Automated Governance Analysis Completed

Human approval remains required. PatchForge does not approve CAB decisions, risk acceptance, patch deployment, or closure autonomously.

- Normalised finding identity
- Bound source provenance
- Applied governance boundary
- Generated Bayesian advisory snapshot
- Recorded live source-feed refresh history

Decision Boundary

PatchForge is a governance product. It does not scan environments, generate exploit code, provide procedural exploit steps, deploy patches, mutate production systems, approve CAB decisions, or accept risk autonomously.

Signed Artefacts

- affected_asset_scope.json
- bayesian_patch_risk_snapshot.json
- compensating_controls_plan.json
- config_applicability_assessment.json
- customer_network_asset_snapshot.json
- exploitability_assessment.json
- finding_intelligence_snapshot.json
- governance_manifest.json
- human_review_state.json
- network_vendor_profile_snapshot.json
- patch_change_readiness.json
- patch_decision_context.json
- patch_feasibility_assessment.json
- patch_prior_update_proposal.json